ÉTICA DEL HACKING · PARCIAL PRÁCTICO

FASE 1 | ARQUITECTURA DEL SOC N1

Caso C05 — PagoClaro Fintech S.A.S.

Diseño de la red, segmentación, flujos de monitoreo, dimensionamiento y decisiones de arquitectura.

Datos del trabajo	Definición
Estudiante	Nelson Enrique Sierra Perez · Modalidad individual
Caso y actividad	C05 — Fintech con pasarela de pagos y billetera digital ficticias
Alcance empresarial	10 empleados, 20 equipos de cómputo y servicios en la nube pública (IaaS)
Alcance implementable	Laboratorio VirtualBox con servidor Wazuh y dos endpoints representativos
Estado del documento	Diseño propuesto. Las pruebas e instalaciones se evidenciarán en las Fases 2–4.

Inventario de referencia — 20 equipos

Tipo de activo	Cantidad	Ubicación lógica	Función
Windows 11 (8 estaciones + 3 portátiles)	11	VLAN 10 · Operaciones	Operaciones, soporte, gerencia y cumplimiento
Portátiles macOS	5	VLAN 10 · Operaciones	Desarrollo y mantenimiento de aplicaciones
Ubuntu Server (aplicación, BD, respaldo)	3	VLAN 20 · Servidores	Aplicación, réplica de base de datos y respaldos
Ubuntu Server (bastión)	1	VLAN 30 · Gestión	Acceso administrativo controlado

Criterio de inventario: Wazuh y la consola de Kaspersky pertenecen a la infraestructura adicional del SOC; no sustituyen los 20 equipos del caso. NGFW, switch y puntos de acceso se contabilizan aparte.

1. Arquitectura empresarial propuesta

Topología lógica del caso C05: acceso de usuarios, NGFW cotizado, switch, dos puntos de acceso, VPN hacia la VPC, tres VLAN corporativas y flujo de eventos hacia Wazuh, Kaspersky y GLPI.

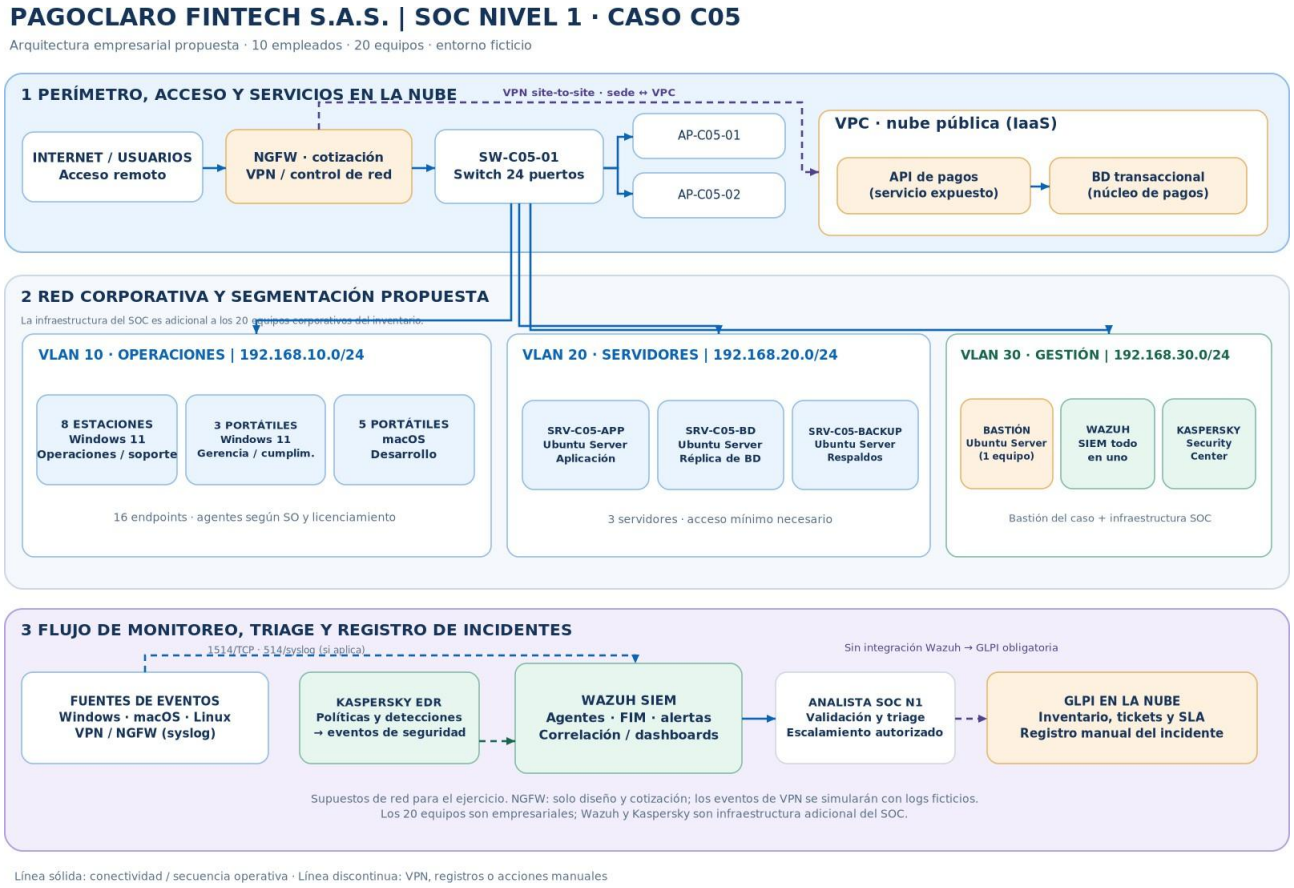


Figura 1. Arquitectura empresarial propuesta (diagrama suministrado por el estudiante).

2. Arquitectura del laboratorio representativo

Laboratorio local sobre Windows 11 con VirtualBox. Se usa Host-only para aislar el tráfico entre máquinas virtuales y NAT adicional cuando se requiera conexión controlada con servicios externos.

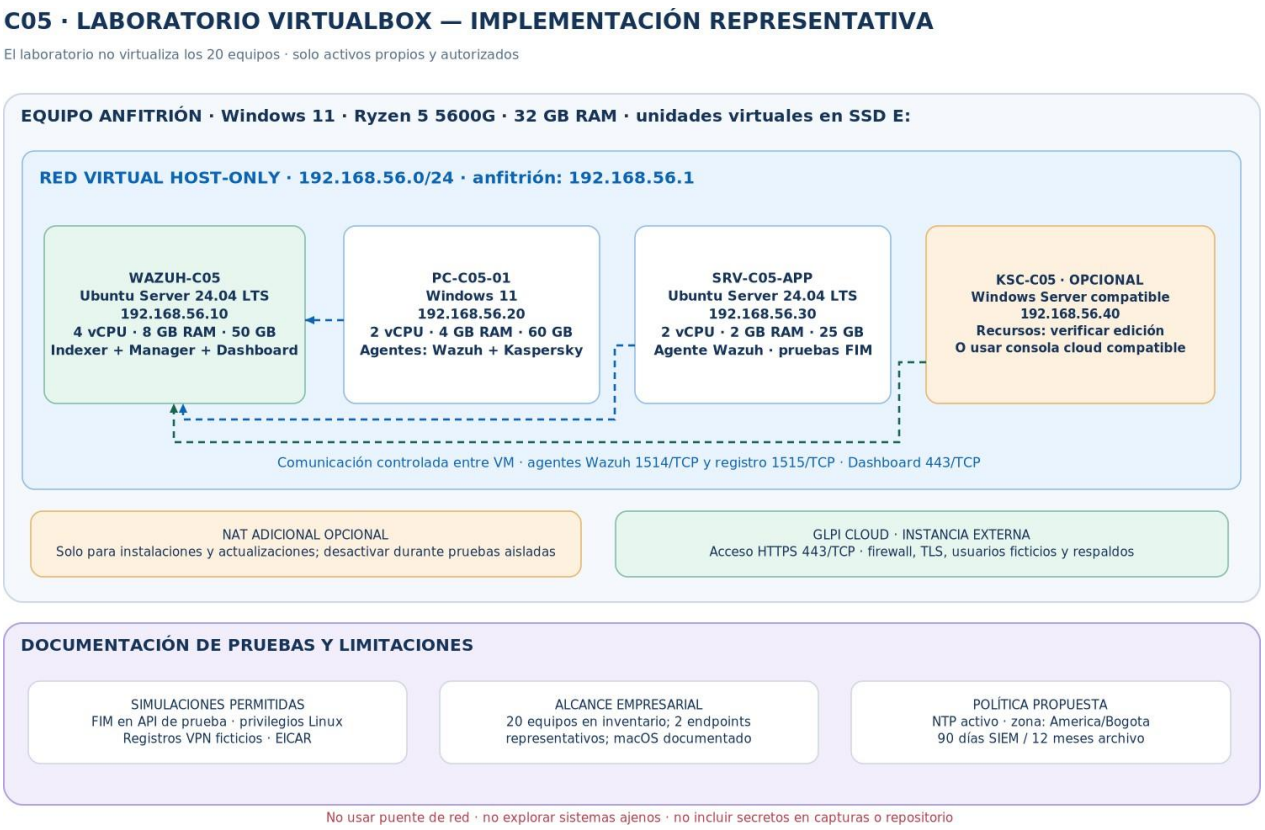


Figura 2. Laboratorio VirtualBox propuesto (diagrama suministrado por el estudiante).

3. Segmentación de red y controles de acceso

La segmentación se define para la red empresarial proyectada. En el laboratorio no es obligatorio desplegar VLAN físicas: se utiliza una red Host-only independiente. Se aplica el principio de mínimo privilegio.

Segmento	Subred / función	Controles propuestos
VLAN 10 · Operaciones	192.168.10.0/24 · 16 endpoints Windows/macOS	Salida web filtrada; acceso a aplicación por HTTPS; sin acceso directo a bases de datos ni administración.
VLAN 20 · Servidores	192.168.20.0/24 · 3 Ubuntu Server	Administración solo desde VLAN 30; acceso únicamente a servicios publicados y agentes de monitoreo.
VLAN 30 · Gestión	192.168.30.0/24 · bastión + SOC	Consolas y administración restringidas al personal autorizado; recepción de eventos desde otras VLAN.
VPC · IaaS	Direccionamiento privado por definir	Núcleo transaccional y API; VPN sitio a sitio; reglas explícitas, sin exposición directa de BD.
Lab Host-only	192.168.56.0/24 · VMs de prueba	Acceso entre VMs autorizadas y anfitrión; conexión NAT adicional controlada para cloud y actualizaciones.

Reglas mínimas entre segmentos

Origen → destino	Servicio permitido / restricción	Justificación
VLAN 10 → VLAN 20	HTTPS 443/TCP hacia aplicación autorizada; bloquear acceso directo a BD	Limitar exposición de recursos de backend.
VLAN 30 → VLAN 20	Administración SSH 22/TCP solo desde bastión / cuentas autorizadas	Separar operación y administración.
VLAN 10/20 → VLAN 30	Wazuh 1514/TCP y registro 1515/TCP hacia el manager	Centralizar telemetría de endpoints.
VLAN 10 → VLAN 30	Sin acceso a consolas administrativas del SOC	Proteger paneles, credenciales y configuración.
NGFW ↔ VPC	Túnel IPsec sitio a sitio, según diseño final	Proteger el enlace con servicios cloud.

Alcance: Los puertos y permisos son reglas previstas para producción; el NGFW únicamente se compara y cotiza en el parcial.

4. Matriz de flujo de logs y comunicaciones

Los flujos se restringirán por firewall y origen autorizado. Los de Kaspersky y Syslog se ajustarán a la edición y al colector efectivamente desplegados.

Origen	Destino	Protocolo / puerto	Información o finalidad
Agentes Wazuh (Win/Linux/macOS)	Wazuh Manager	1514/TCP	Eventos de autenticación, FIM, SCA y actividad del endpoint.
Agentes Wazuh	Wazuh Manager	1515/TCP	Registro inicial de agentes.
Analista N1	Wazuh Dashboard	443/TCP (HTTPS)	Consulta de alertas, agentes y dashboards.
NGFW / concentrador VPN	Colector Syslog / Wazuh	514/TCP o UDP (propuesto)	Registros de VPN, bloqueos e intentos de acceso.
Kaspersky / conector	Colector Syslog / Wazuh	514/TCP o UDP, si compatible	Alertas del endpoint en CEF/Syslog, según consola licenciada.
Endpoint con Kaspersky	Consola Kaspersky	Según producto y edición	Políticas, estados, tareas, detecciones y gestión de agentes.
GLPI Agent en endpoints	GLPI Cloud	443/TCP (HTTPS)	Inventario automático y datos de activos.
Analista N1	GLPI Cloud	443/TCP (HTTPS)	Apertura, triage, seguimiento y exportación de tickets.
GLPI Cloud	Servicio SMTP autorizado	587/TCP (STARTTLS, si aplica)	Avisos y notificaciones de tickets.
Servidores / dispositivos	Servicio NTP	123/UDP	Sincronización temporal para correlación de eventos.
Analista autorizado	Bastión Linux	22/TCP (SSH, restringido)	Administración controlada de servidores de prueba.

Integración: La guía solicita recepción de eventos Kaspersky mediante CEF/Syslog. No se presupone un envío directo desde cualquier versión Cloud: debe verificarse y probarse en la Fase 3.

5. Dimensionamiento y crecimiento

La capacidad empresarial es de 20 agentes; se prevé 30 % de expansión (20 × 1,30 = 26 agentes). Para Wazuh se toma la referencia de la guía para hasta 25 y para el tramo de 26–50 agentes. Los recursos son estimaciones a verificar mediante uso real de CPU, RAM, disco y eventos por segundo.

Componente	Laboratorio representativo	Proyección / criterio de dimensionamiento
Wazuh: indexer + manager + dashboard	VM Ubuntu Server 24.04 LTS; 4 vCPU; 8 GiB RAM; 50 GB SSD; 192.168.56.10	26 agentes: 8 vCPU, 8 GiB RAM, 100 GB iniciales; aumentar disco si se indexan eventos del NGFW o sube la tasa de alertas.
Endpoint Windows	Windows 11; 2 vCPU; 4 GiB RAM; 60 GB; 192.168.56.20	Representa 11 estaciones y portátiles Windows; agentes Wazuh y Kaspersky compatibles.
Endpoint Linux	Ubuntu Server 24.04 LTS; 2 vCPU; 2 GiB RAM; 25 GB; 192.168.56.30	Representa servidores Ubuntu; pruebas FIM, autenticaciones y eventos de aplicación.
Kaspersky EDR/XDR	Consola cloud compatible o VM Windows Server opcional (192.168.56.40)	20 endpoints; confirmar licenciamiento y compatibilidad por SO y requisitos de consola antes de desplegar.
GLPI Cloud	Instancia externa HTTPS; referencia 2 vCPU, 4 GB RAM, 40 GB SSD	10 usuarios ficticios, ~20 activos; dimensionar adjuntos, backups, inventario y servicios.

5.1 Justificación de la capacidad

Para las pruebas se monitorean dos endpoints (Windows y Linux) conectados a un Wazuh todo en uno. El inventario del caso conserva los 20 equipos originales y su incorporación se planifica en etapas. El margen de seis agentes permite crecimiento sin cambiar la topología lógica del SOC.

Condición de cálculo: 90 días de consulta en el SIEM es una meta propuesta, no una garantía de capacidad: debe verificarse el uso de almacenamiento una vez habilitados FIM, SCA y las fuentes Syslog.

6. Servicios transversales y conservación de evidencias

Servicio / política	Configuración propuesta	Control de verificación
Sincronización y zona horaria	NTP activo; zona America/Bogota; registrar hora de evento en UTC o con offset	Comparar fecha/hora en anfitrión, VMs, Wazuh y GLPI.
Identificación de activos	Nombres C05: WAZUH-C05, PC-C05-01, SRV-C05-APP, KSC-C05 (opcional)	Correspondencia entre inventario, alertas y capturas.
Retención en SIEM	90 días de consulta de eventos / alertas	Verificar política de índices y uso del almacenamiento.
Archivo de evidencias	12 meses de archivo protegido, sujeto a revisión normativa	Control de acceso, integridad y exportación de evidencias.
Respaldos	Copia diaria de configuraciones SIEM y GLPI; respaldo periódico de inventario y tickets	Documentar al menos una prueba de restauración.
Protección de información	Registros y tickets confidenciales; credenciales y llaves restringidas	Anonimizar evidencias y excluir secretos del repositorio.

7. Decisión de arquitectura del SIEM

Selección: Wazuh todo en uno

Se propone desplegar indexer, manager y dashboard en una sola máquina Ubuntu Server. Para un laboratorio académico con dos endpoints y proyección de 20 agentes, esta arquitectura reduce el consumo de recursos, simplifica la instalación y facilita las demostraciones de FIM, SCA, alertas y respuesta activa.

Una arquitectura distribuida sería apropiada ante necesidades de alta disponibilidad, separación de funciones o mayor tasa de ingesta. Esas condiciones no se exigen para este laboratorio y aumentarían el número de VMs y los recursos del equipo anfitrión.

Límites explícitos: El diagrama empresarial es una propuesta; los logs VPN se simularán con registros ficticios; el NGFW no se instalará; la disponibilidad de integración Kaspersky–Wazuh y de GLPI Cloud dependerá de pruebas posteriores.